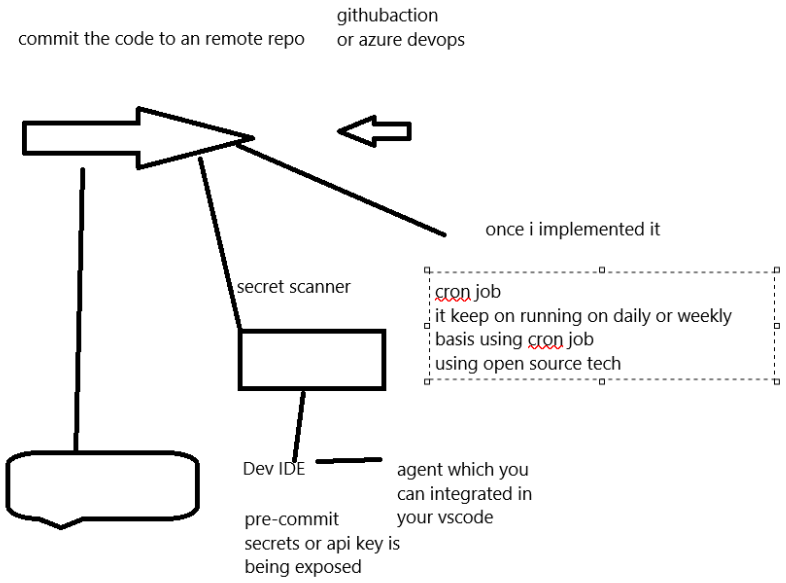
DevSecOps

Monday, March 2, 2026 9:59 AM

DevSecOps
What is the need of DevSecOps in organization.
Problem with traditional environment in your SDLC

1. Security is added too late
2. Manual security reviews
3. Compliance delay
4. Volunaribility in production

#############even amazon azure they also cannot come out of the solution
Aws azure both are down for more than 6 hours.
No.
Ai this is the reason
#you need to
Shift Left implemeting security at the starting of the project



3/2/2026 10:14 AM - Screen Clipping

If we move to devsecops pipeline using a cicd tools.
Final deployment it will be faster or slow

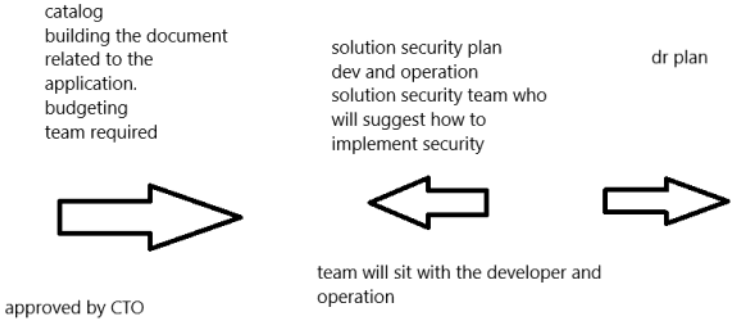
Drawback of DevSecOps

1. Resitance: development team
2. Pipeline bottleneck: automation scanning can delay the deployment speed any
3. False postive: SAST DAST tool can flag non-issues
4. Resource consuming will increase
5. Accountability

Encourage the development and operation team to be learn this tools

Walmart is an store which required some complaince PCI compliance. We prefer GCP
Walmart any application health care industry will be deployed in azure HIPAA

Walmart in our own cloud openstack
Only on the new application side



3/2/2026 10:31 AM - Screen Clipping

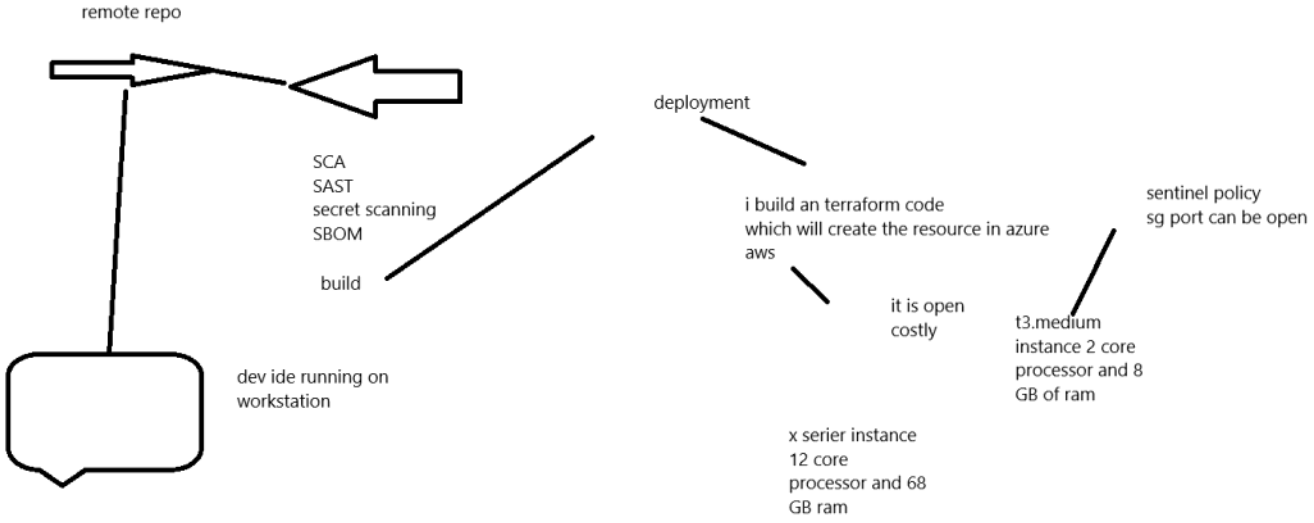
In the development phase there is an Software Bill of Material: - component libraries and dependency in the software

License Compliance
Regularity Compliance:

#we work with socgenerale
Anything we want to implement in france software need to be always approved from the labour union

Get the image from a particular repo

Once we build our application we want to deploy it in the cloud.
Coding
Aws: cft: cloud formation to
Azure: arm template
Terraform. iAC scanning valunaribility in operation.
Image: container: synk trivy



3/2/2026 10:59 AM - Screen Clipping

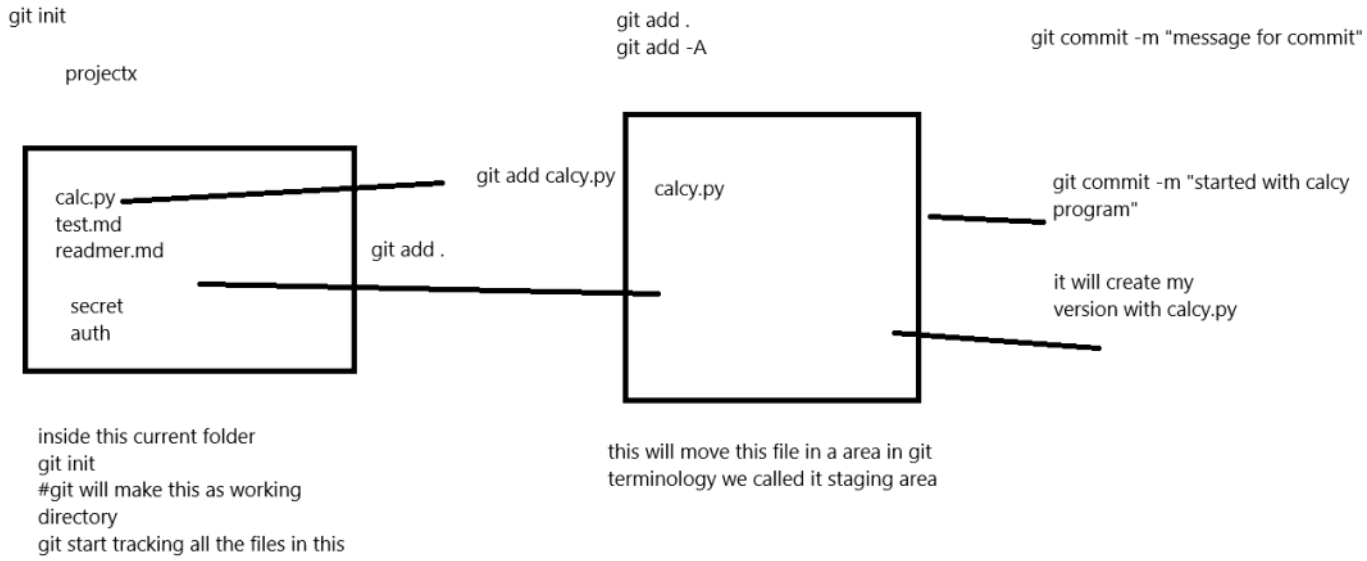
Artifactory:

Handon

Monday, March 2, 2026 11:00 AM

We will upload an code in a github

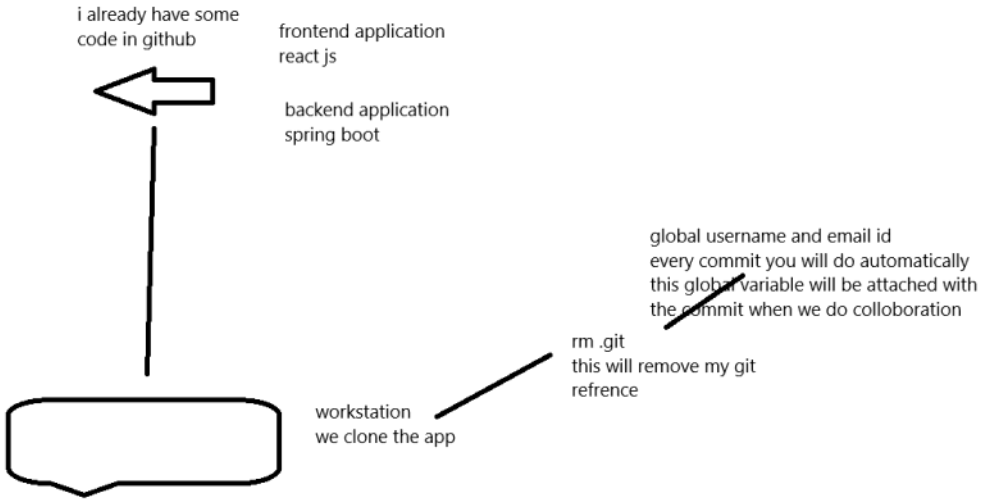
1. We will create an github action workflow using yaml
2. We will create a valunaribiliy in our application property file
3. Then create a new branch upload it
4. We will create a pr request
5. That time codesweep will run which will give me the valunariblity report
6. Also it will publish it in asoc



Recap

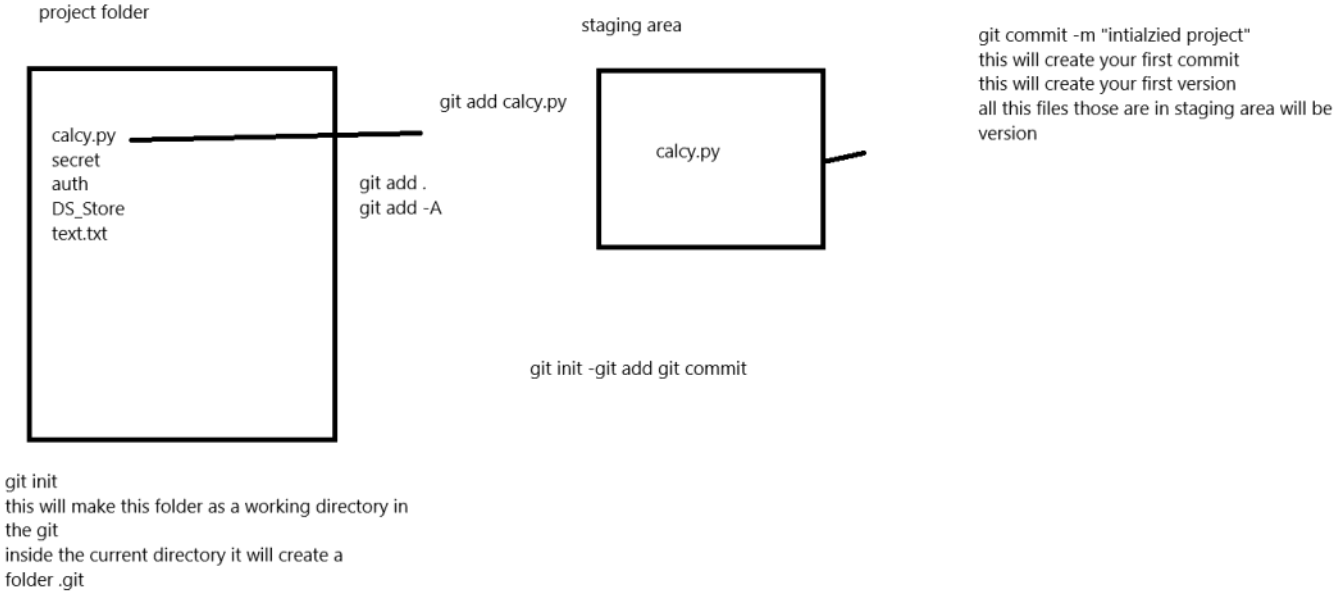
Tuesday, March 3, 2026 9:33 AM

We upload a code in github



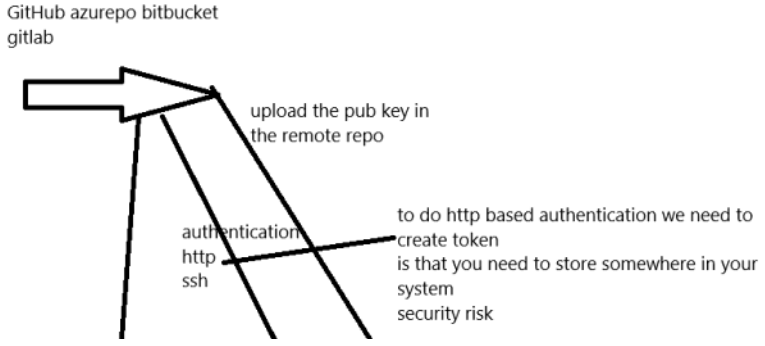
3/3/2026 9:39 AM - Screen Clipping

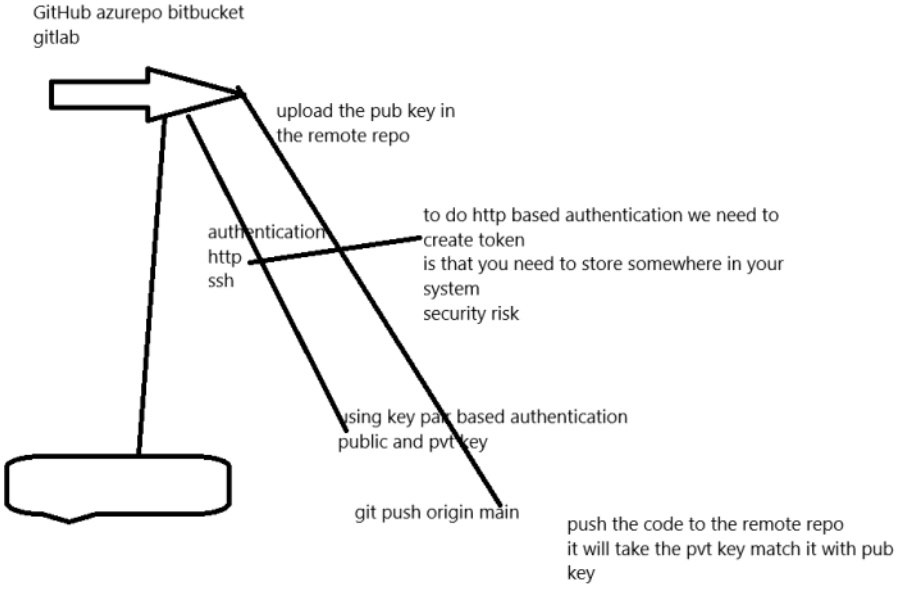
Git workflows



3/3/2026 9:44 AM - Screen Clipping

The commit we have done it in local machine I need to upload the same in the remote repo





3/3/2026 9:49 AM - Screen Clipping

Topics

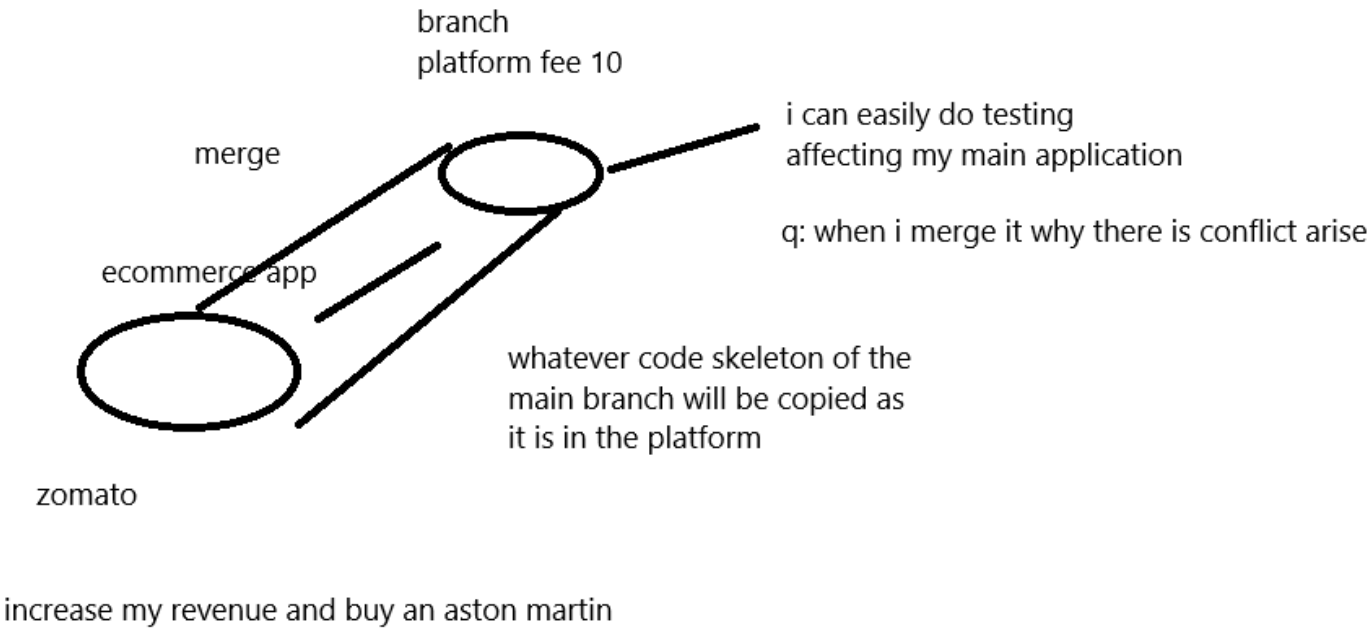
Tuesday, March 3, 2026 9:49 AM

Git branches
Then build our github action pipeline.

Branches

Tuesday, March 3, 2026 9:50 AM

Git branch is required before you create your pipeline.



3/3/2026 9:57 AM - Screen Clipping

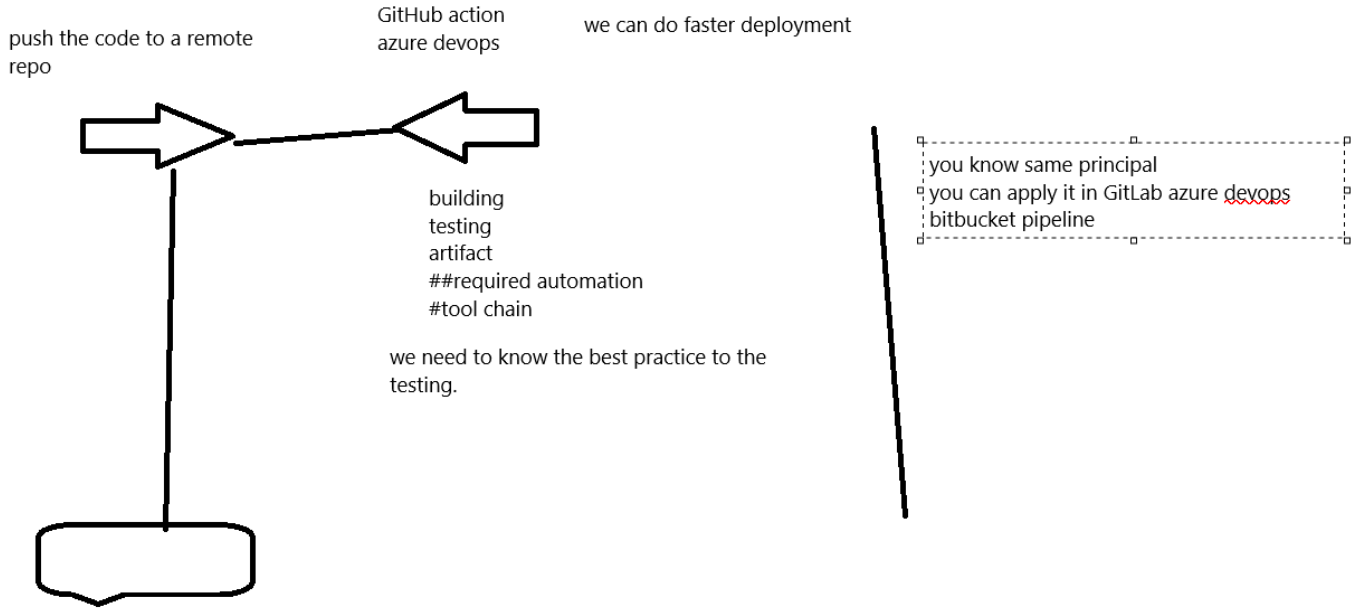
1. Communication between your team. Stop multiple people working on the same project. 500 project running. We need to always avoid wastage. Adt: template for every single application ssp dr. documentation jira
2. Sprint: one week break down large task into smaller short livea branch
3. Regulary pull from the destination to the main branch

Rebase: this will remove all the new feature
Retrospective : sit and talk
Mistake always start from the development side.

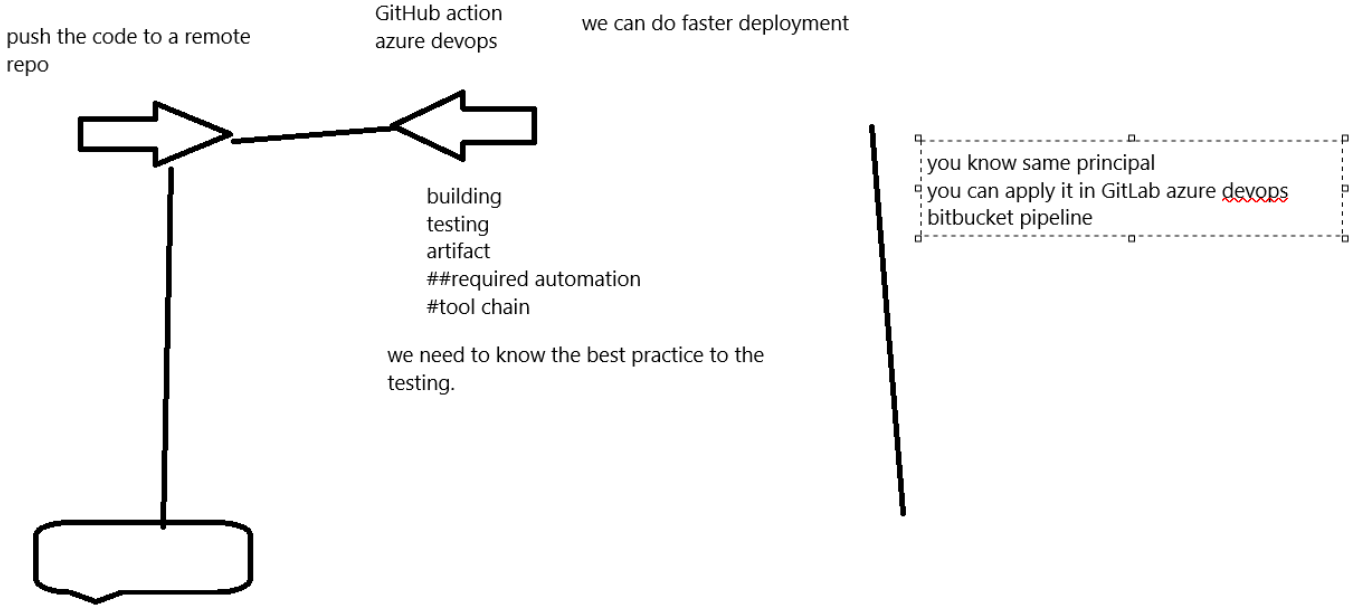
Automation

Tuesday, March 3, 2026 10:09 AM

It is nothing simple use the available tools to avoid mistakes.
Yeasterday we have upload the code.



3/3/2026 10:14 AM - Screen Clipping



3/3/2026 10:14 AM - Screen Clipping

workflows

Tuesday, March 3, 2026 10:14 AM

Key concept

a. Workflows : this can be a folder inside this you will have an file in yaml format which is going to execute azure-devops.yml
b. What is yaml it is like xml
c. Indentation in yaml happen using two spaces

Action:

List of items

1. Build the code
- build
2. mvn clean package
3. if there is a failure in the build what will be the next items feedback to the developer
4. Test it
5. Unit test

We called this as a dictionary in programming langauge python

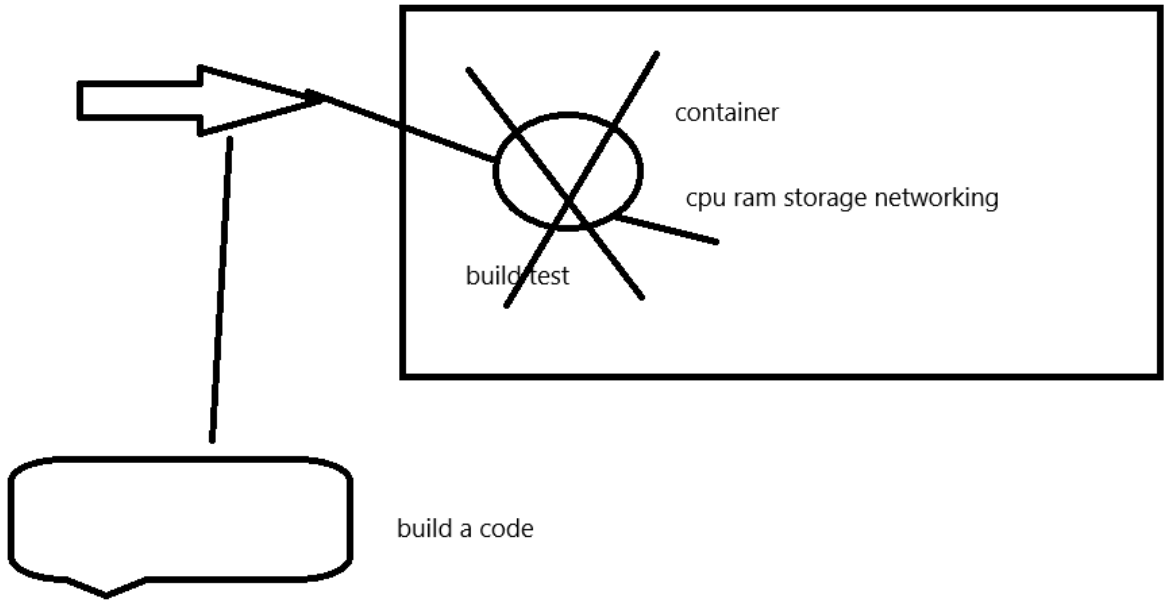
Java

{}

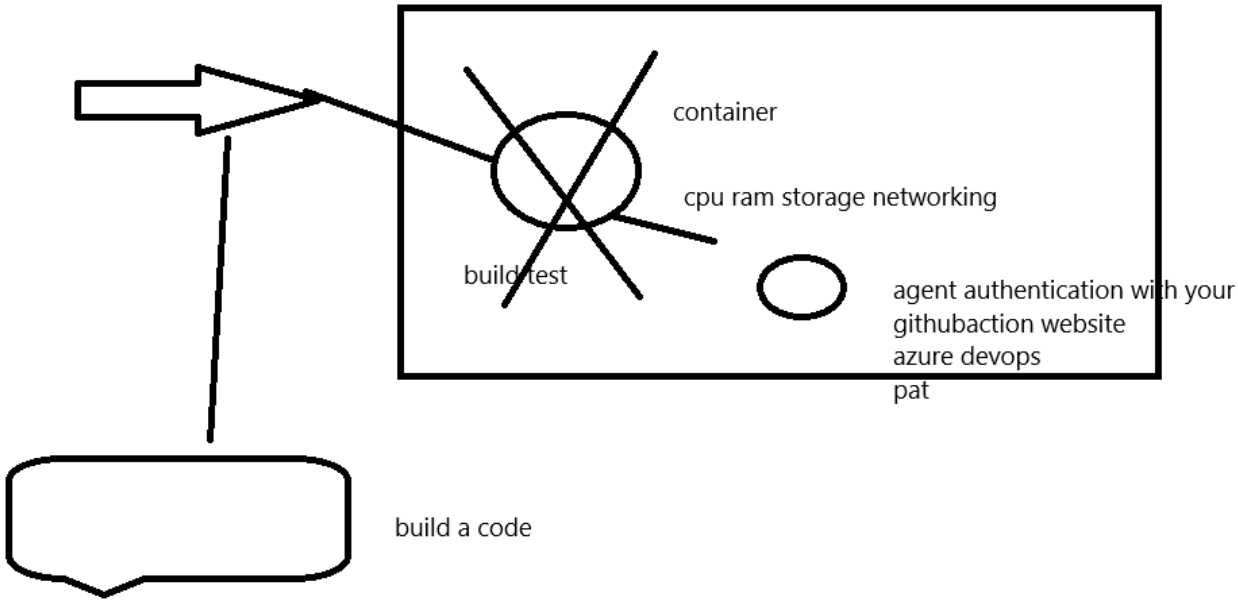
Action Pipeline

Tuesday, March 3, 2026 10:22 AM

Workflows: the complete automation process define in yaml. .github/workflows/ci.yml
#this workflow need to execute
Event: push, pull_request, schedule time. A workflow that tigger on a particular time. Cron job
Jobs: it will be set of steps that execute on the same virtual machine(called a runner). The default behaviour in github action is that multiple jobs run in parallel. In azure devops every single job execute one by one. If you want put dependency in github action you can do it.
Steps: an individual task that execute on virtual machine called as runner. Like running an shell script or bash script.
Mvn clean package
Npm ci
Action: you want to run that inside a k8s cluster. Argo cd iuntegration and build dev test staging prod.
Runner: github action provide you with runner you can also self host your runner.



3/3/2026 10:41 AM - Screen Clipping



3/3/2026 10:43 AM - Screen Clipping

We will create our first job

Tuesday, March 3, 2026 10:44 AM

Run it using github action.

I will be contributer to this project who is going to create the develop branch

#before I compile to test it
This job is going to run on ubuntu machine which is plan vanil vm
We need to setup spring boot application it required java

1. To add java
2. Unit test : mvn test
3. Build the package skip the unit test
4. Upload the jar file

Generate an bugs in the application and interact with hclapp scan

Workflow

Thursday, March 5, 2026 9:36 AM

We seen integrating github action with your code.
Next time when the developer push the code automated build should happen.,
If there is an build failure automatically a feedback will be given to you and you will receive an alert
We created a folder .github/workflows/ we created the yaml file where we have define the workflow.

Needs: all the jobs will run in parallel . If my frontend job is completed start with backend job.
It is called as sequential workflow.

All the jobs are running using github provided hosted runner

Selfhosted runner

Thursday, March 5, 2026 9:52 AM

Runner: vm with cpu ram storage and networking.
Security background. Trust is always a challenge
I want to execute it in my own environment. Physical virtual machine or a container. Which will execute github action job,. You will have full control over the hardware software and networking.
You will increase the security the os where we are running will be hardened better performance with large build

You need to manage this hardware and maintencea cost will be there.

What is the multiple reason that we are using self hosted runner.

1. Better security
2. Plenty of vm are laying ideal
3. Cost
4. Custom tools

The time it is consuming cpu ram storage networking we are paying.

Where we will use an self-hosted runner to build our job

Self hosted runner

Thursday, March 5, 2026 11:04 AM

Self hosted runner in github action or azure devops

1. It will give you isolation in infrastructure network isolation and when you properly implement it will you an clean environment.
2. Devsecops always github enterprise

Network security : this runner will sit inside a private network. All your workflow will securly access a database staging envrionment or may be some internal api
Infrastructure control: you maintain the os pathces and security tools you will get total control over the environment
Ephermal runner: once job completed you will close the runner
Runner Group: you can restrict which repo or organization can use specific runner reduce unauthorized access
Data control: sometime ml learning for us government project. Fedramp. GDRP. Nothing need to be run on cloud it need to have an isolated environment in on prem
devsecops

SAST

Thursday, March 5, 2026 11:10 AM

The primary purpose of SAST static application security testing tool used in DevSecOps.

1. Analyze your code. It can be developer code or can be IAC.
2. Before we created a binary file
3. We need to anlyze source code bytecode withough execution the application so that I can easily find out security valnurability bugs and flaws early in the development process SDLC.
   We will get shift-left approch
   Shift left security at the beginning. Early valnurability detection.
   Immediate feedback is required
   Prevent security bugs
   Atomated complaince
   Developer education

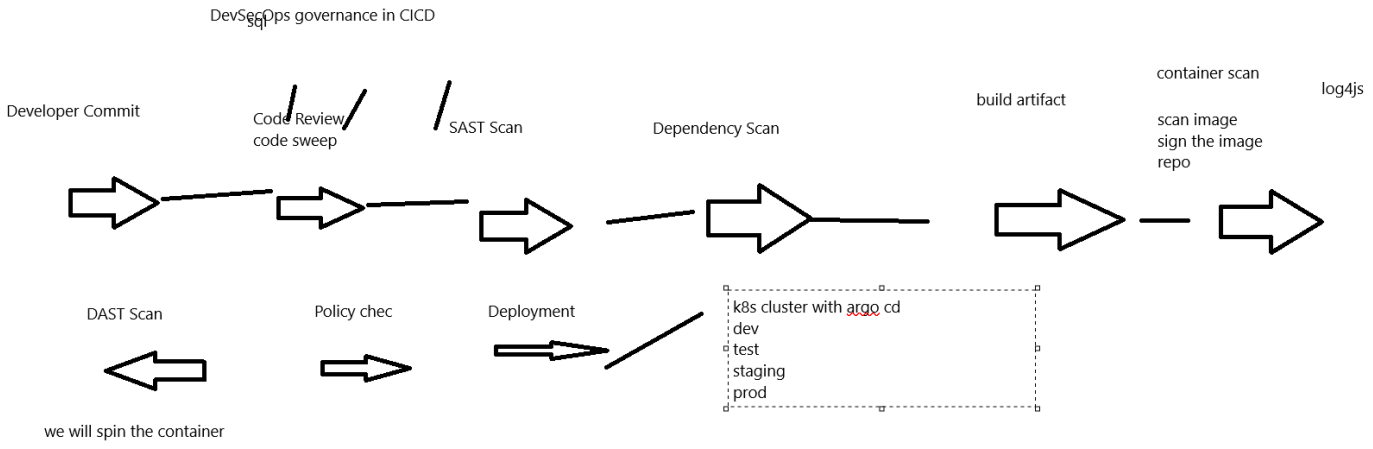
   So this is like an whitebox testing unlike your DAST black box testing.

   #it cannot identify any bugs in third party application.
   Google ad word. Api integration from google. Dynamic application testing
   There may be a changes of high risk sometime false postive
   Report is static it become oudated quickly
   Cron job to run it on daily basis.

   DevSecOps it is not an concept
   It is a list of tool chain which provide you with security in dev ops

   Vulnarability types.

   SAST
   SCA: bill of material
   Secret scanning
   Zero trust



3/5/2026 11:35 AM - Screen Clipping

Devesec governance role

Thursday, March 5, 2026 11:36 AM

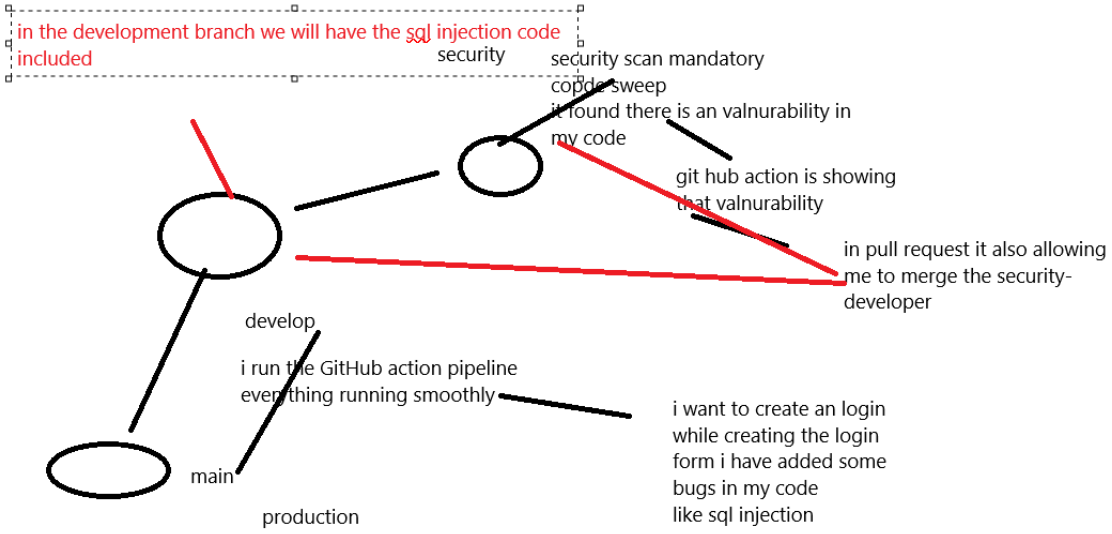
1. DevsecOps architecture: define all the governance framework
2. Security enginner: implement security control
3. Devops enginner: integrate all this security control
4. Complaince office: ensure regularty complaince
5. Developer: follow secure coding practive

Push the code to the repo
Branch are being created so that we are not disturbing the existing code
Github action pipeline/azuredevops pipeline
-appscan sast scan
Dependency scan
Docker image scan
Terraform secdurity
Deployed to k8s
Security montiing tools

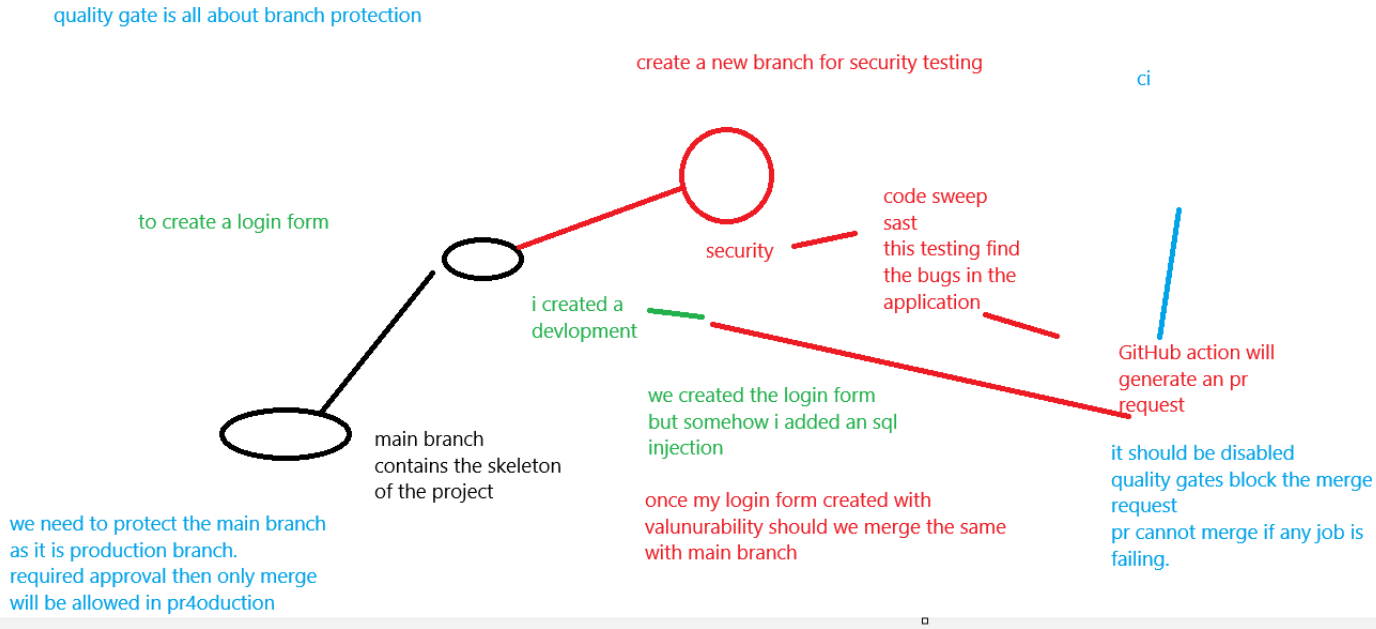
Recap

Friday, March 6, 2026 9:41 AM

Valnurabiltiy detected the sql injection ---while doing pr merge with your branch main production branch. My merge branch in enabled and we click on merge--



3/6/2026 9:55 AM - Screen Clipping



3/6/2026 10:04 AM - Screen Clipping

Quality gate as of now we know that we can implement using github branching strategy.
DORA metrics DevOps Research and assement.
Deployment Frequency
Lead Time for change
##velocity
Change failure rate
Time to restore my service
##stability in my application.
Silos
team

Quality gates in github

Friday, March 6, 2026 10:19 AM

1. We will first add an valnurability in the application
2. Try to merge it it will work

#we will add quality gates in github branch protection approval add it and try to merge
This will not work at all previous branch is failing till we do not pass the branch all the quality gate it will not allow me to merge it.

We are going to add an new feature and do security testing on the new feature in a new branch is the testing has been passed then only merge it with development branch with the pull request

Friday, March 6, 2026 1:01 PM

Pipeline using docker container do valnurability check and upload the image to a repo

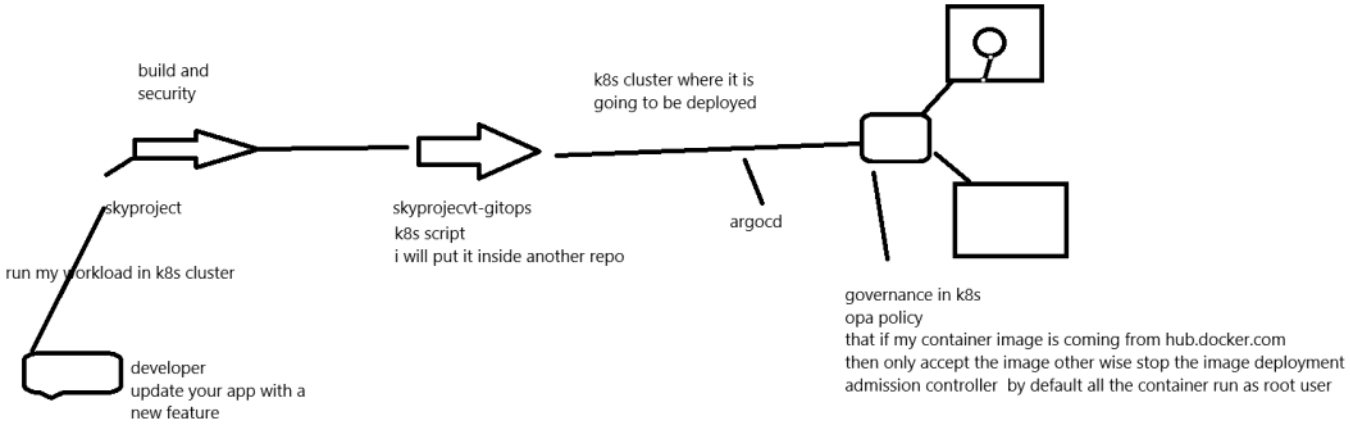
1. We will put docker image scanning
2. Docker image sgnature
3. Quality gate in the docker iso
4. Spin up the container scan the image for DAST
5. Before it goes into prod
6. Governance in the docker container
7. Add the deployment in k8s with multiple environment you can see the pipeline with the different type
8. Argocd
9. Upload the image in the docker hub

Gitops enterprise flow

Monday, March 9, 2026 9:46 AM

Gitops enterprise flow. For DevSecOps platform

1. Best Practices for your security gates
2. Fail the build on critical valnurability
3. Run your scan early in the pipeline
4. Use policy as code
5. Integrate with pull request check
6. Maintain vulnerability threshold
7. Automated remediation suggestion.

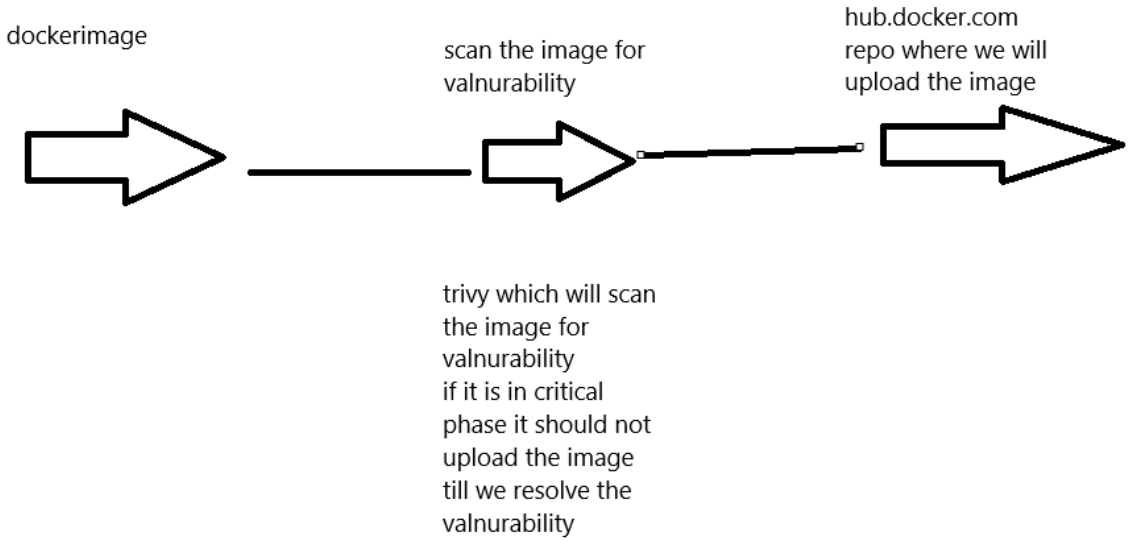


3/9/2026 10:05 AM - Screen Clipping

Hub.docker.com

Monday, March 9, 2026 10:43 AM

We need to convert this application into an container based image and upload the same into hub.docker.com



3/9/2026 10:46 AM - Screen Clipping

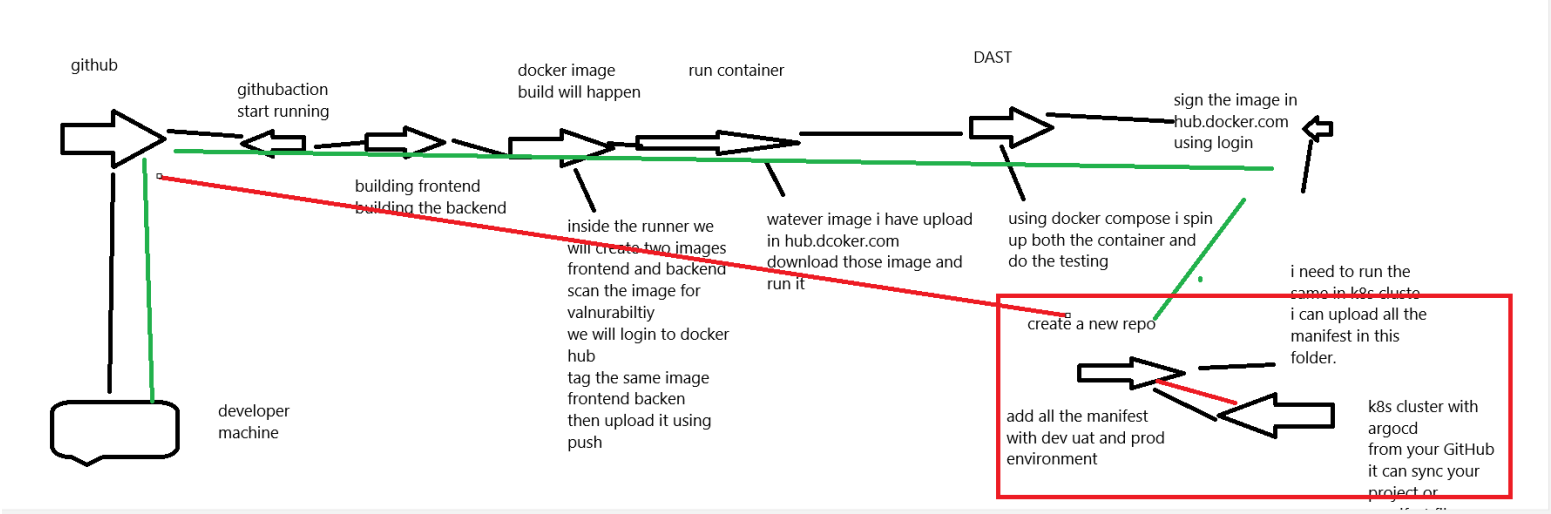
CKA
CKS
Add your docker hub username and password as an varaible

Lets test the image for vulnerability

Monday, March 9, 2026 12:06 PM

We want to run the container first check the valnurability using dast testing.
Dynamic testing means I need a runnable environment
You need k8s cluster.
Use a docker compose file which will spin up my container and give me an runnalbe environemnt

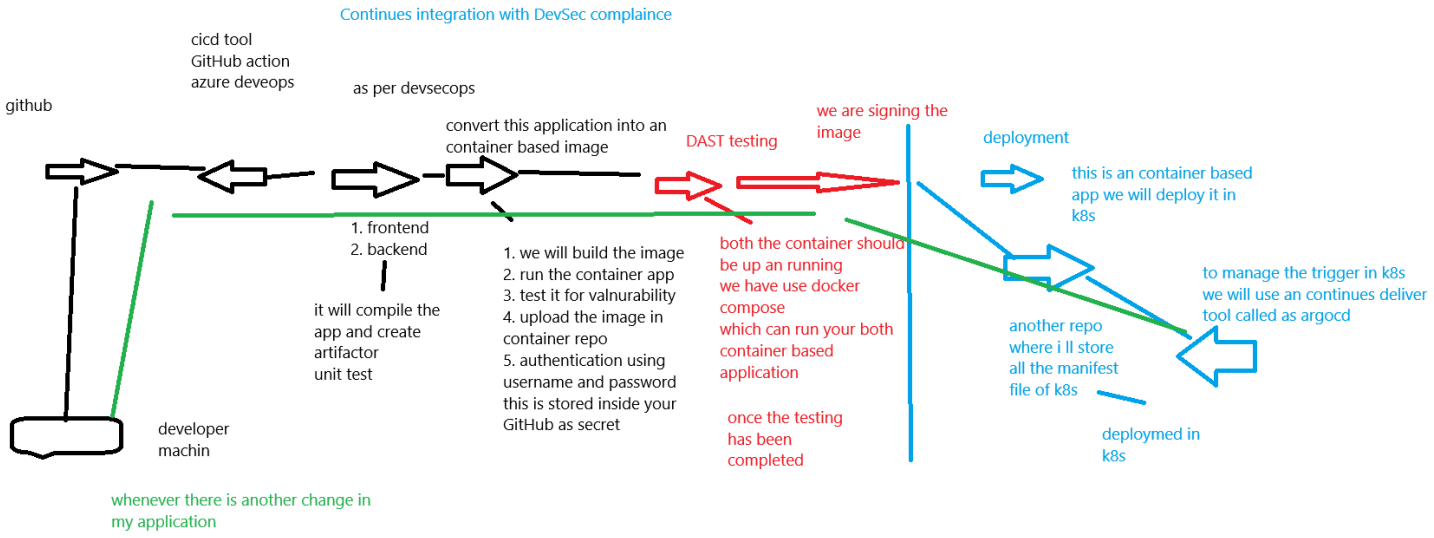
Lern about docker compose this will help you to test your container in running environment using github action



3/9/2026 1:22 PM - Screen Clipping

Recap

Tuesday, March 10, 2026 9:47 AM



3/10/2026 9:57 AM - Screen Clipping

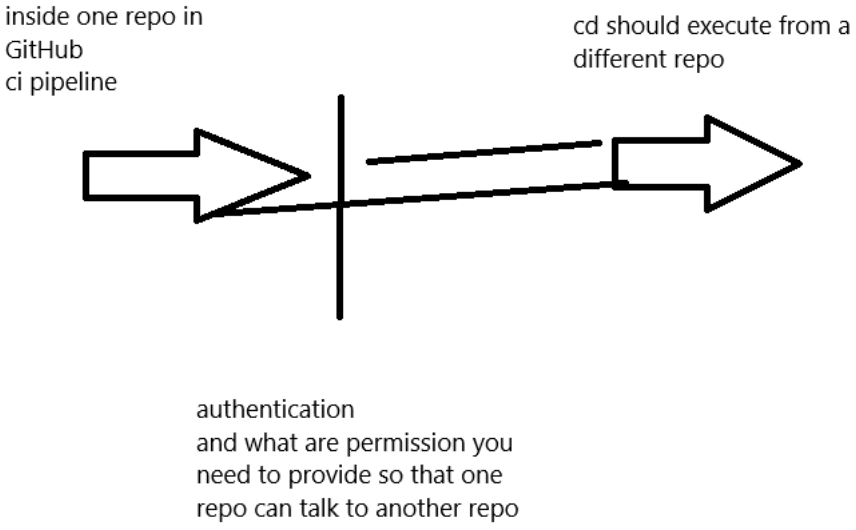
Continues deployment

Tuesday, March 10, 2026 9:57 AM

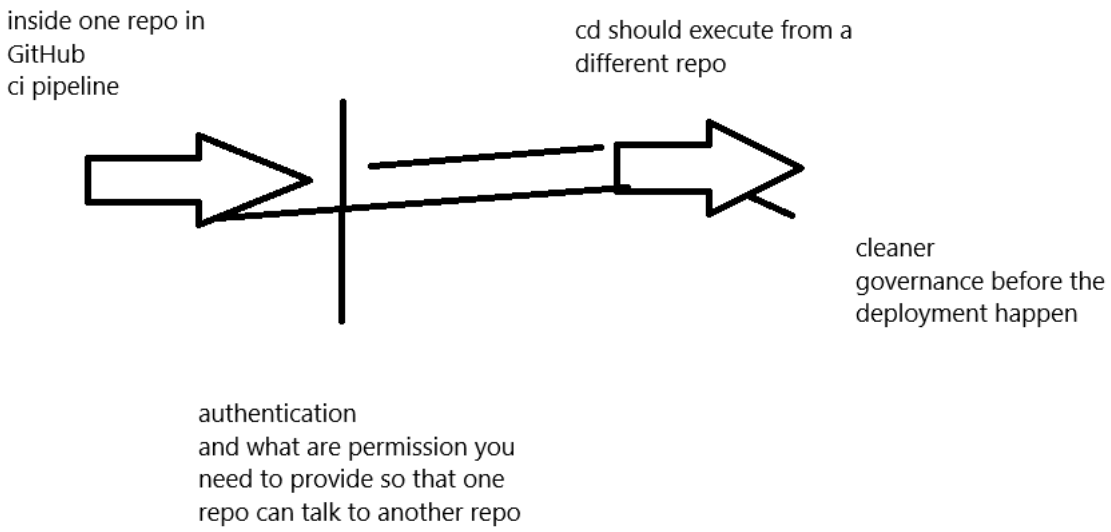
When we want to do continues deployment in k8s we need to add an tool which is automatically sync your repo

1. You also need to user tool argocd
2. Harness : paid product

Sogeneral
Walmart
##it detect the changes in your application and update the deployment automatically in k8s



3/10/2026 10:02 AM - Screen Clipping



#to do the continues deployment process we will use k8s I have already a cluster created
How to add yourself in the cluster we will

Azure devops

Wednesday, March 11, 2026 9:49 AM

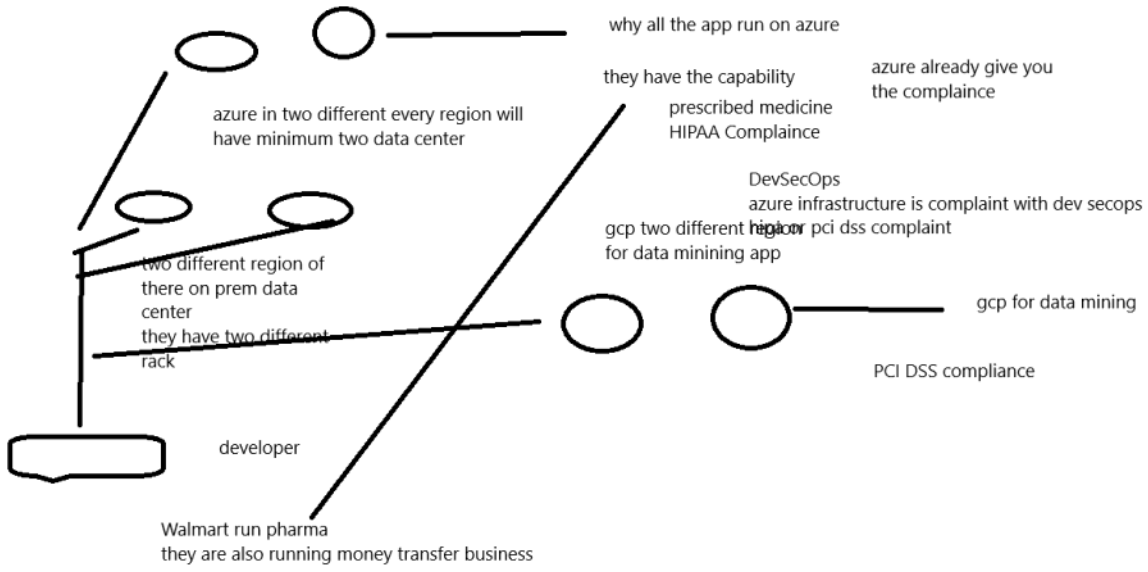
Azure devops
It is the first platform which is used to build our cicd pipeline.
Why azure devops.

A single platform to manage everything.
Action
Gitlab
Bitbucket the pipeline
Circle ci

Azure devops become so much popular
All the tools depends on continues delivery on other platform. K8s aks eks gke. Deployment is required in vm you reuqired a cloud serivce provider

Those who are in microsort house they will get the continues delivery platform using azure cloud

Walmart
It is one of biggest store in us
There stores are like an football field size 107 stores
2000 stores
Omni channel online retailing 5 years
They have an cloud strategy 2x2x2



3/11/2026 10:08 AM - Screen Clipping

Active directory on prem can in integrated directly with azure.
Entra id
Azure devops co pilot. Ai agent
Asses your whole environemnt do an anlytics convert generate transformation. Diagram also mckup tools qa assitant
Don't deepened on the same.

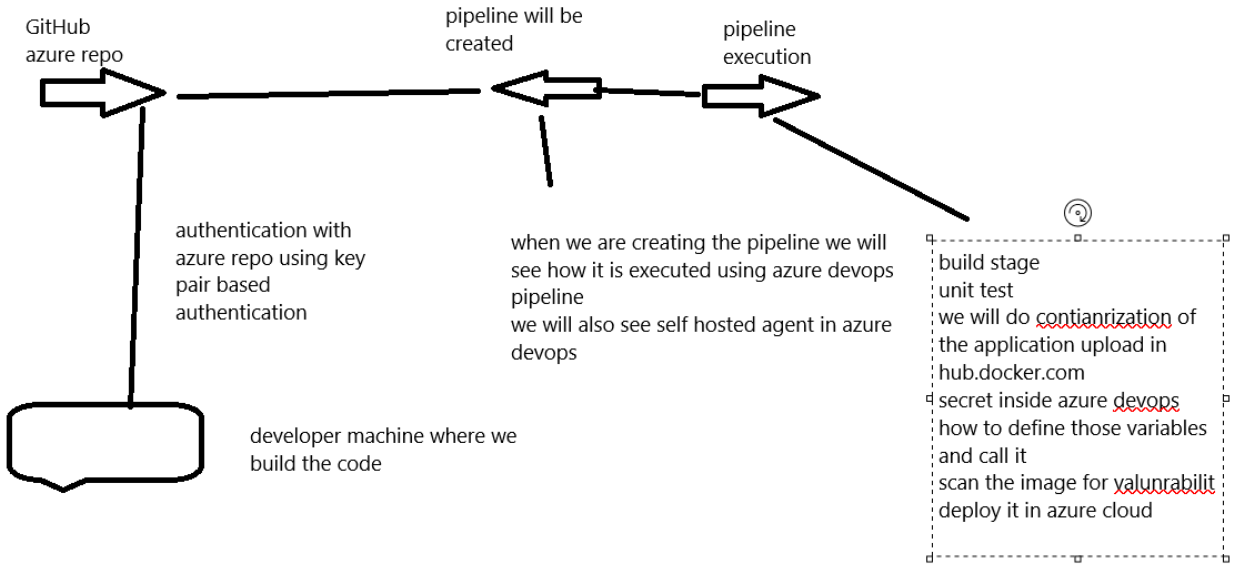
Devsecops: I want to implement in my organziuation . Choose azure. Continues deployment. We have azure cloud.

Why we go to Dmart/Jiomart to purchase or grocery. 90% useless we buy it.
Azure devops a single platform where we got everything even the deployment platform also.
This platform provide complainces like HIPAA and PCI DSS.

Master card they used to store indian customer information in some of there data center in USA.
They stop iisuing new card for almost 6 month
Now they have data center in azure. In india
Aws don't do business in midle east or saudi. Bharin
Governance.

Wednesday, March 11, 2026 10:29 AM

How to implement dev sec ops in azure. Till know we have done the deployment in k8s cluster
As we have azure cloud we require a vm also to be deployment.
Ened to end cicd pipeline with azure devops and deploy in azure cloud using a vm
But before the deployment is done we need to scan the infrastructure for valnurability
Networking
Firewall
Storage
Vm



3/11/2026 11:36 AM - Screen Clipping

Shared Responsibility Model

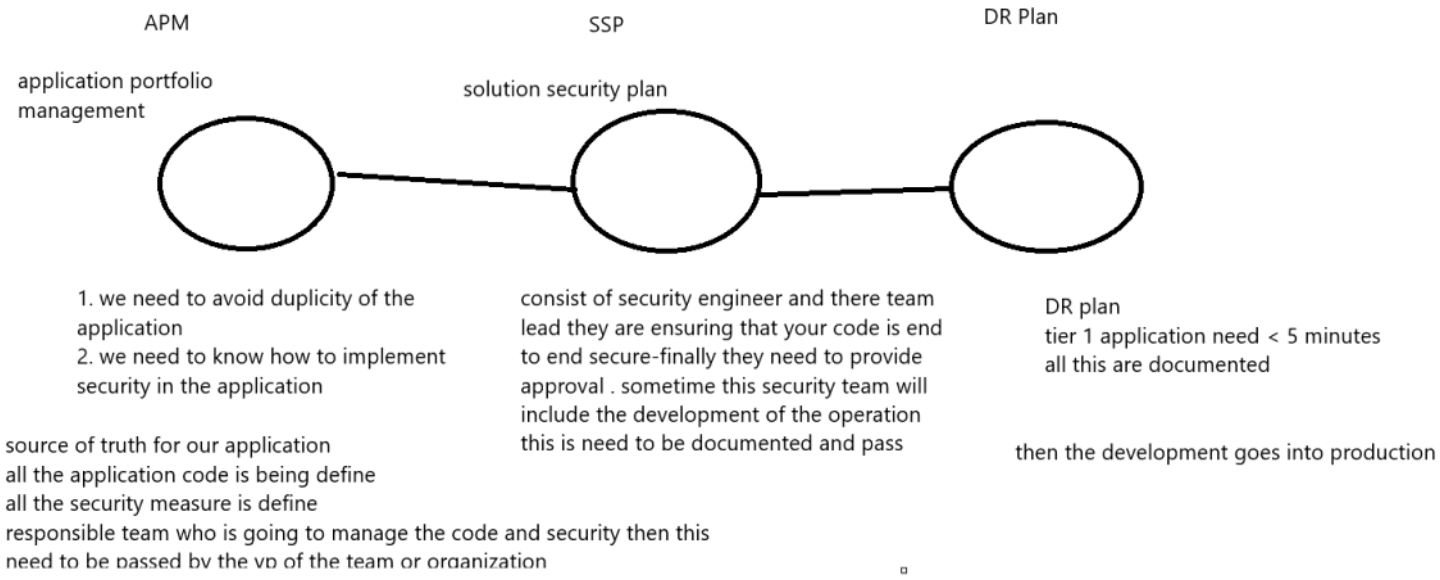
Thursday, March 12, 2026 9:46 AM

As an security profession what is your responsibility?

1. To perform all the testing
2. Sharing of reports tru false analysis
3. Governance
4. Compliance and policy enforcement

10,000 application running. Used by different team in usa only we have more than 545 stores. Every single store is like an football feel size.
IKEA.
We are launching a new application for logistics park. They can easily track the logitics hub around the world
CTO ask one question how about security in the application.
On our developed side we have implemented security . Mvn test npm test and they have created something called as end security in the application. Did u talk to the security team that your application is complaince as pe us norms
Did u talk the operation team who is managing the environment.

There is no cordination between all this team members. Deployment cycle is always slower
Lets add security team in devops model.
DevOps Model -- security team
This security team create problems. Security Control constrain in there development.
Initial delay in the delivery
Requirement of security control



3/12/2026 10:13 AM - Screen Clipping

It extends the devops philosophy

retrospective

Thursday, March 12, 2026 10:20 AM

Standup meeting. Meeting.

Actionable items. Well prepared
1. A blameless meeting held at the development cycle or after a security incident has happen
2. How to integrate security into the development process
3. How to integrate security into the operation process

Velocity of your SDLC will be slow.
What we miss valnurability scan result and complaince check
Actionable items
Continues improvement is always required. Root cause analysis
There you will find some team member don't speak at all
1. Feeling low
2. Trouble

Create anonymous loops. Much need information will be easily shared.
Actionable followup: action item it need to be actually implement rather than forgotten
Azure devops has something called as board which has a built in extension which can facilitate there respospective allow team to create boards add feedback you can convert the same into actionable items.

Review incident. Why what are top reason that the incedent is happen

Analyze Metrics: you have define security related KPI
1. Valnurability counts
2. Test coverage

MTTR: mean time to remediate
Share the update in change in the policy
Governance policy
Automation
#####################
Mastercard two years back master card ceo and cto need to resign immediately. All the indian people data is used to store outside the country in USA. As per RBI regulation they have that for the next siz month they cannot issue any new card to any person in india till they don't put the data back to india
GDRP

Feature	Devops	Devsecops
Focus	Speed and efficency	Secure software at speed
Security	Address after the development	Embedded in every stage proactive
Responsibility	Mostly dev and ops team	Shared across dev,sec,ops
Automation	Focus will always in dev and operation	Automation security check and complance

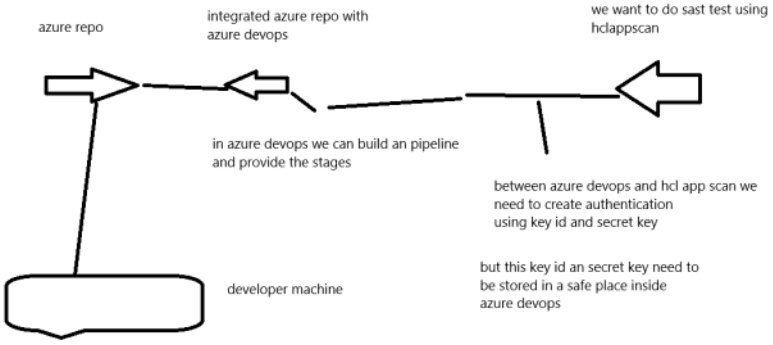
Devsecops

Thursday, March 12, 2026 10:48 AM

45 application it took almost more than 2 years to complete 20 person security team
C language memory leak issue. There are few hardware in our warehouse that run on c language

The new team which comes we are ensuring that it consiste of dev ops and security
We train them for almost 5 days. They have to pass an exam . Once they pass it to do deployment in production.
APM-ssp-dr for a days

1. Carefully planning.
2. And reduce the friction for the team.
3. Colloboration
4. Effective communication to unify around the same goals



3/12/2026 12:01 PM - Screen Clipping

Lets do the integration

Thursday, March 12, 2026 12:11 PM

To make this pipeline an enterprise grade azure devsecops pipeline. We should provide devsecops control (security gates + governance + complaince check) across your ci

1. Build
2. Unit test
3. SBOM generation
4. SAST(HCL APP Scan)
5. Then only artifact will be created and published

#Mandatory control

1. Branch control
2. Dependency vulnerability scan
3. Scret scan
4. SAST quality
5. Container scaning
6. Artifact sigining
7. Policy enforcement
8. Security report publishing

Recap

Friday, March 13, 2026 9:47 AM

1. We have create an azure devops pipeline for SAST testing
2. We difine stages
3. Inside the stage before my application artifact get created I need to complete my security scan
4. Once the code is upload we need to git leaks we are checking for any api key or secret key or access key is being bundled inside your code or not.
5. Maven build and unit test. So if developer is added any unit test it should be full fill.
6. We want to integrate appscan for sast testing.

a. We install an appscan plugin inside github
b. We have make a connection to app scan using secret key and access key.
c. We need to add an stage isnide the pipeline so that my sast testing will be completed.

For the deployment contianer and k8s

Container

Friday, March 13, 2026 11:35 AM

In place of vm deployment we are using contianers.
They are small executer running on top of your vm.
Full fledge operation system with your application running on top of an vm
They run as an process id using cggroup and namespace

Whole ai
When you ask a question. It gives you answer. Prompt to the ai.
It need to process your request using llm it required cpu ram storage networking.
For every single prompt I cannot allocate an full virtual
We spin up a container as process id. It will do my llm provide an answer to the same.
Netflix uber

The problem with contianer is that it always

1. It is light weight you remove everything even the security
2. But this contianer run as an root user.

CD
WCNP

When you add more security always you will get friction from the development team?
Retrospective
Blame game
Ai
In wgt we introduce ai on january github co pilot